

DESARROLLO DE SISTEMAS WEB

Licenciatura en Ingeniería de Ciberseguridad e Infraestructura de Cómputo

Modelado de amenazas

V. Seguridad en el desarrollo de aplicaciones web

Saberes teóricos

Información de la EE

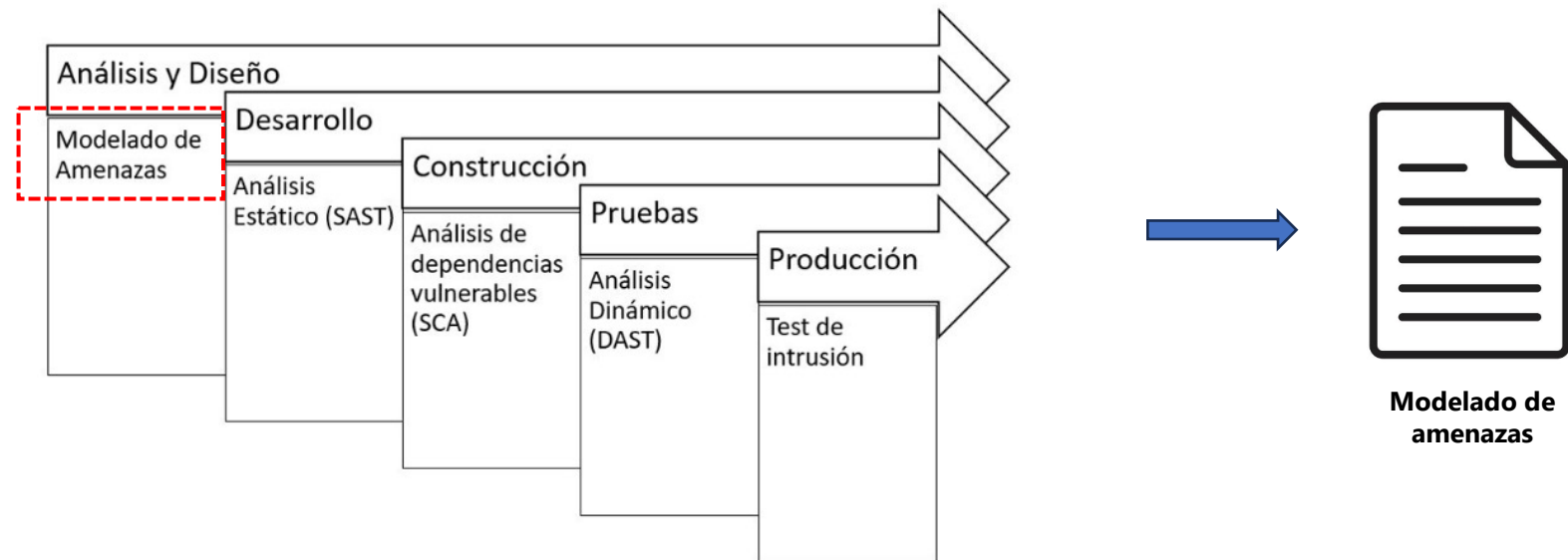
V. Seguridad en el desarrollo de aplicaciones web

- Modelado de Amenazas

Definición

Modelado de amenazas

- Según la fundación **OWASP** (*Open Web Application Security Project*), un referente metodológico en el terreno de la ciberseguridad a nivel global, el modelado de amenazas es un proceso que permite **identificar, cuantificar y abordar** los riesgos de seguridad asociados a una aplicación.
- Se usa en el **desarrollo seguro de software** a lo largo de todo su ciclo de vida. **El documento resultante** es el modelado de amenazas para la aplicación.



Objetivos

Modelado de amenazas

- **Identificar** requisitos, amenazas, riesgos, controles de seguridad.
- **Cuantificar** el nivel de impacto de cada riesgo en el sistema o aplicación a modelar y en la organización.
- **Abordar** poner en marcha medidas y controles de seguridad eficaces para mitigar los riesgos con éxito y responder a los potenciales ataques.

El **modelado de amenazas** no debe ser considerado como una actividad aislada, sino que **tiene que estar perfectamente alineado con las prácticas de desarrollo de una organización**, atendiendo no solo a las primeras fases de desarrollo, sino también a todos los cambios de diseño que se producen a lo largo del ciclo de vida.

Proceso de desarrollo de software seguro

Modelado de amenazas

Introducción

- Objetivo del proyecto.
- Alcance del proyecto.
- Metodología.

Análisis de requisitos

- Requisitos funcionales.
- Requisitos no funcionales.
- Casos de uso (análisis).
- Riesgos de seguridad identificados.

Proceso de desarrollo de software seguro

Modelado de amenazas

Diseño seguro

- Arquitectura del sistema.
- Descripciones de casos de uso.
- Diseño arquitectónico.
 - Vista de casos de uso (diagrama UML de casos de uso).
 - Vista lógica (diagrama UML de clases).
 - Vista de implementación (diagrama UML de componentes).
 - Vista de procesos (diagramas UML de secuencia).
 - Vista de despliegue (diagrama UML de despliegue).
- Modelo de amenazas.
- Modelo de datos (DER).

Proceso de desarrollo de software seguro

Modelado de amenazas

- **Construcción segura**
 - Selección justificada de lenguajes y frameworks seguros.
 - Descripción de la configuración del entorno de desarrollo.
 - Programación defensiva (segura).
 - Implementación del backend.
 - Autenticación y autorización.
 - Estrategia de integración segura con la base de datos.
 - Implementación del frontend.
 - Diseño responsivo.
 - Estrategia de comunicación segura con el backend.
 - Validaciones del lado del cliente.
 - Seguridad: almacenamiento y gestión de contraseñas.
 - Estrategias de cifrado.
 - Política de contraseñas seguras.
 - Medidas contra vulnerabilidades comunes (SQL Injection, XSS, CSRF).
 - Implementación de roles de usuario.

Proceso de desarrollo de software seguro

Modelado de amenazas

Pruebas de seguridad

- Pruebas de penetración.
 - Inyección SQL.
 - Ataque DoS (prueba de estrés).
 - CSRF.
 - XSS.
- Análisis estático de código.
- Escaneo de vulnerabilidades.
- Presentación de resultados.

Proceso de desarrollo de software seguro

Modelado de amenazas

Despliegue seguro

- Descripción de la configuración de servidores y servicios.
- Estrategia de respaldos.
- Descripción del monitoreo y respuesta a incidentes.

Mantenimiento seguro

- Soporte a usuarios.
- Monitoreo y auditorias de seguridad.
- Agregar nuevas funcionalidades.
- Corregir defectos.
- Planear nuevas versiones.

Elementos

Modelado de amenazas

Mediante el **modelado de amenazas** es posible representar de forma estructurada toda la información relacionada con la seguridad de un activo. De ahí que, a la hora de efectuar un modelado de amenazas, **OWASP** considere que se deban incluir elementos como:

- La **descripción** del activo que se procede a modelar. Nombre, versión, descripción, propietario, participantes y revisor.
- Los **diagramas de flujo de datos** que describen el funcionamiento de la aplicación en términos de seguridad.
- Un **listado de las amenazas** potenciales que pueden poner en jaque la seguridad del sistema a modelar.
- El **conjunto de medidas** que se tienen que tomar para mitigar las amenazas y prevenir incidentes de seguridad.
- Las **acciones** que se van a llevar a cabo para validar el modelo y comprobar que las medidas son eficaces.

Preguntas clave

Modelado de amenazas

En los niveles más altos, cuando elaboramos un modelo de amenazas, formulamos cuatro preguntas clave:

- **¿En que estamos trabajando?** En primer lugar, hay que tener claro cuál es el objeto que se va a modelar.
- **¿Qué puede ir mal?** En esta pregunta entran en juego las amenazas que se ciernen sobre el sistema o la aplicación.
- **¿Qué vamos a hacer al respecto?** O, dicho de otra forma, qué contramedidas se pueden implementar para gestionar los riesgos de forma eficaz.
- **¿Hicimos un trabajo suficientemente bueno?** La evaluación de los controles adoptados es clave en materia de ciberseguridad.

Etapas del modelado de amenazas

Modelado de amenazas

- OWASP contempla **tres fases** fundamentales en el modelado de amenazas:

1. Descomposición de la aplicación para entender cómo funciona.
2. Determinar y clasificar las amenazas.
3. Determinar contramedidas y mitigación.

A estos tres pasos podríamos **añadir una fase final**, focalizada en analizar la eficiencia de todas las acciones llevadas a cabo.

4. Determinar la eficiencia de las acciones llevadas a cabo.

Etapas del modelado de amenazas

Modelado de amenazas

- Así, cada paso del modelado de amenazas vendría a responder una de las cuatro preguntas clave del manifiesto del modelado de amenazas.

Manifiesto	OWASP
¿En que estamos trabajando?	Descomposición de la aplicación para entender cómo funciona.
¿Qué puede ir mal?	Determinar y clasificar las amenazas.
¿Qué vamos a hacer al respecto?	Determinar contramedidas y mitigación.
¿Hicimos un trabajo suficientemente bueno?	Determinar la eficiencia de las acciones llevabas a cabo.

1. Descomponer la aplicación

Etapas del modelado de amenazas

1. Descomponer la aplicación

Modelado de amenazas

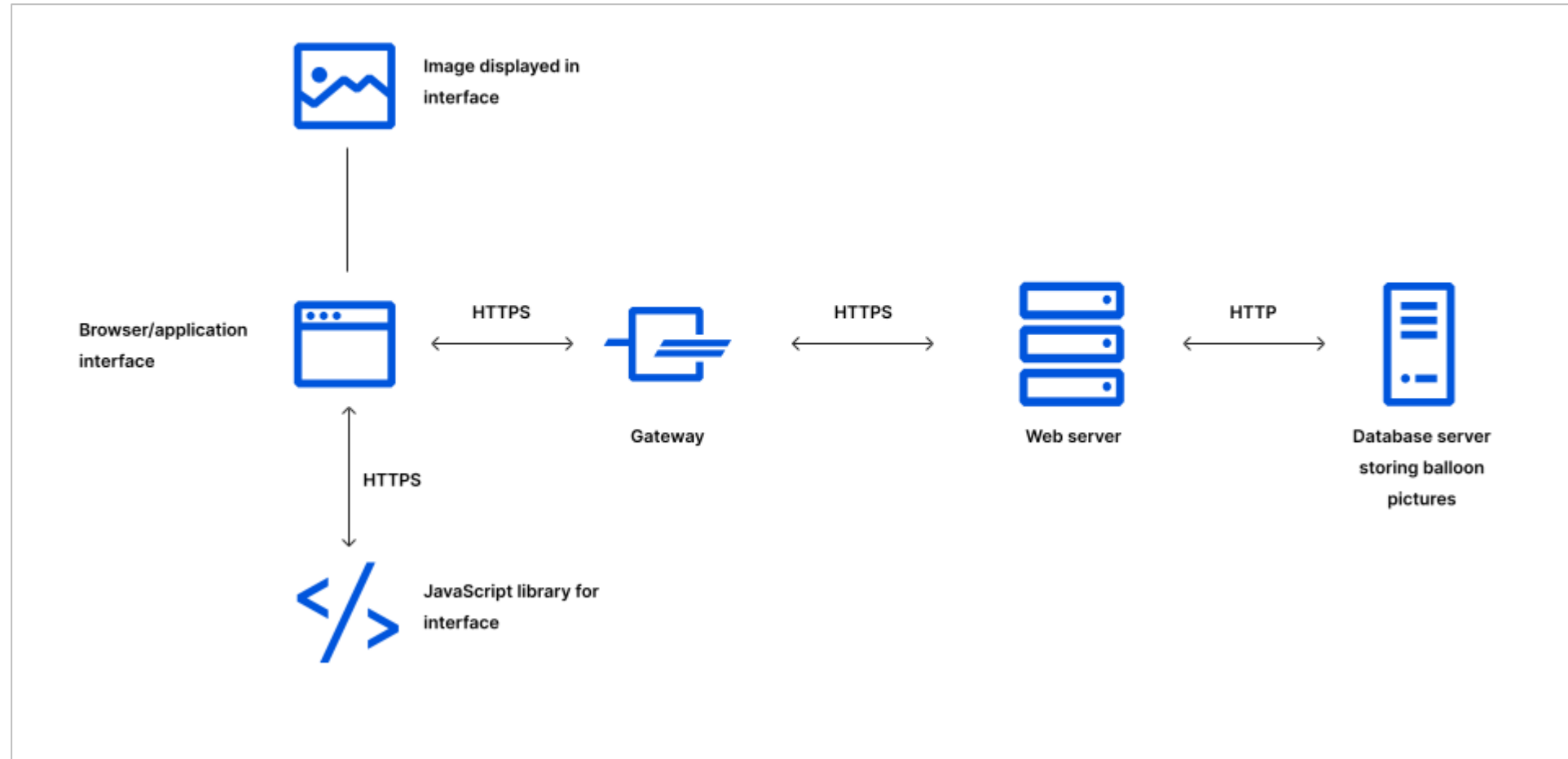
En esta fase el objetivo central es entender a la perfección cómo funciona la aplicación o el sistema y cómo interacciona con elementos externos. Para ello se debe:

- **Recopilar la información sobre la aplicación a modelar.**
- **Identificar los niveles de confianza** que representan los derechos de acceso a la aplicación o al sistema que se está modelando.
- **Evaluar las dependencias externas.**
- **Identificar los puntos de entrada y de salida** para los ataques.
- **Listar los activos** que podrían ser atacados.
- Esto permite establecer los derechos de acceso o los privilegios para cada punto de entrada, así como para interaccionar con cada activo.
- A partir de esta información se pueden **elaborar diagramas de flujo de datos** para comprender las rutas del sistema y tener en cuenta los límites de privilegios que se establecen.

1. Descomponer la aplicación

Modelado de amenazas

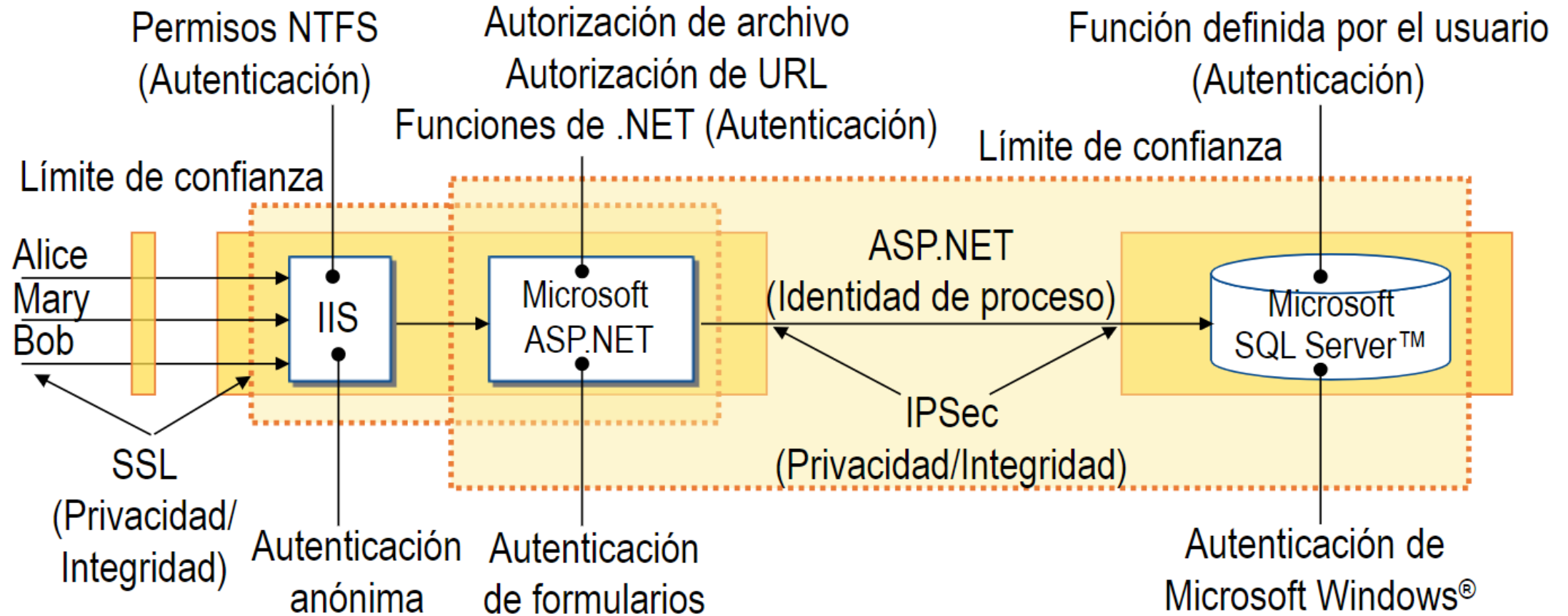
CREAR UN DIAGRAMA DE LA ARQUITECTURA DE LA APLICACIÓN



1. Descomponer la aplicación

Modelado de amenazas

CREAR UN DIAGRAMA DE LA ARQUITECTURA DE LA APLICACIÓN



2. Determinar y clasificar las amenazas

Etapas del modelado de amenazas

2. Determinar y clasificar las amenazas

Modelado de amenazas

A partir de toda la información recopilada y sistematizada en el primer paso del modelado de amenazas, se debe proceder a identificar y clasificar las amenazas potenciales. OWASP propone, dentro de esta fase, los siguientes pasos:

- **Categorizar las amenazas** para poder identificarlas de una forma sistematizada y repetible, empleando metodologías como **STRIDE**.
- **Analizar las amenazas**, teniendo en cuenta la probabilidad de que ocurra un ataque, así como su impacto y el coste que puede acarrear para la organización. Para llevar a cabo esta tarea se pueden diseñar matrices. Las amenazas se analizan tanto desde la perspectiva de los potenciales atacantes, como desde el punto de vista de la defensa, estudiando los controles de seguridad que sirven para mitigarlas.
- **Establecer un ranking de las amenazas** en función de factores de riesgo como impacto, posibilidad o facilidad de explotación. De esta manera, se obtiene una lista de amenazas con un orden de prioridad, de cara a llevar a cabo la mitigación y subsanación de los problemas relacionados con las amenazas con un mayor nivel de riesgo.
- **Mapear casos de abuso**. Es decir, listar y modelar posibles ataques o escenarios maliciosos.

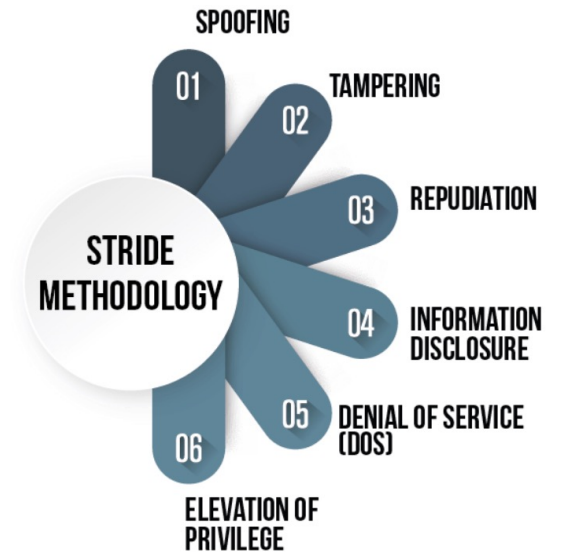
Metodologías de modelado de amenazas

Modelado de amenazas

S.T.R.I.D.E.

El nombre de este framework, diseñado por **Microsoft**, es el resultado de las iniciales en inglés de las seis categorías de amenazas sobre las que se articula:

- **Spoofing** (Suplantación de Identidad)
- **Tampering** (Manipulación)
- **Repudiation** (repudio)
- **Information disclosure** (Revelación de Información)
- **Denial of service** (Denegación de Servicio)
- **Elevation of privilege** (Elevación de Privilegios).



Estas amenazas tienen asociadas sus respectivos controles de seguridad, para poder mitigarlas.

Metodologías de modelado de amenazas

Modelado de amenazas

- Por ejemplo:

Spoofing (Suplantación de identidad)

Id	Amenaza	Activos afectados	Descripción
S-1	Suplantación de solicitudes HTTP	ACT-1, ACT-12	Un atacante puede enviar peticiones falsificadas directamente al backend simulando formularios legítimos.
S-2	Suplantación de usuario administrador	ACT-13, ACT-14	Un atacante podría intentar acceder al servidor mediante SSH utilizando credenciales robadas o débiles.

Tampering (Manipulación)

Id	Amenaza	Activos afectados	Descripción
T-1	SQL Injection	ACT-3, ACT-4	Inserción de código SQL malicioso mediante formularios web.
T-2	Manipulación de parámetros POST	ACT-1, ACT-4	Alteración de campos enviados desde formularios antes de llegar al servidor.

Valoración de las amenazas

Paso 2. Determinar y clasificar las amenazas

Determinar cuál es el impacto que representa la amenaza haciendo uso del método **DREAD**. Con este método, se valorarán las cuestiones siguientes para cada amenaza:

- **Daño potencial (Damage potential)**: ¿cuál es la magnitud del daño que puede causar?
- **Reproductibilidad (Reproducibility)**: ¿es fácil reproducir el ataque?
- **Explotabilidad (Exploitability)**: ¿es fácil que un atacante consiga explotar una vulnerabilidad?
- **Usuarios afectados (Affected users)**: ¿cuántos usuarios se verían afectados?
- **Detectabilidad (Discoverability)**: ¿es fácil encontrar la vulnerabilidad?

Valoración de las amenazas

Paso 2. Determinar y clasificar las amenazas

En este tipo de valoración, se pueden utilizar los valores de alto/critico, medio y bajo, que se cuantifican.

1 a 3 es bajo

4 a 6 es medio

7 a 10 es alto

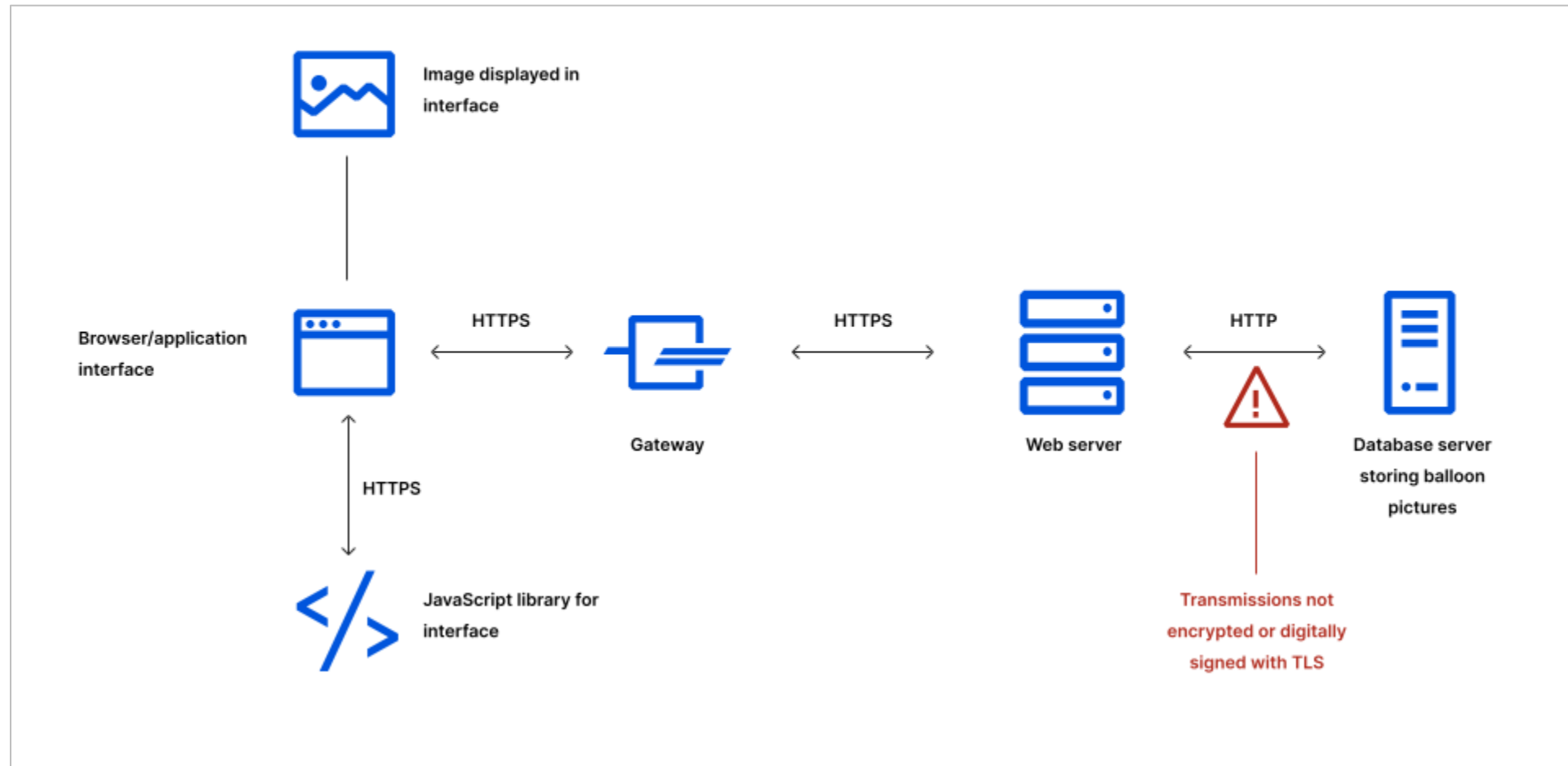
En cada amenaza se evalúa cada uno de los factores DREAD y finalmete:

$$Riesgo = \frac{D + R + E + A + D}{5}$$

No	Id	STRIDE	Amenaza	D	R	E	A	D	Promedio	Nivel
1	S-1	Spoofing	Suplantación de solicitudes HTTP	6	8	7	6	7	6.8	Medio
2	S-2	Spoofing	Acceso SSH no autorizado	9	5	5	9	5	6.6	Medio
3	S-3	Spoofing	Suplantación del servidor sin HTTPS	9	8	7	8	7	7.8	Alto
4	S-4	Spoofing	Falsificación de cabeceras HTTP	6	7	6	6	7	6.4	Medio
5	T-1	Tampering	SQL Injection	10	9	8	9	8	8.8	Crítico
6	T-2	Tampering	Manipulación de parámetros POST	7	8	8	7	8	7.6	Alto
7	T-3	Tampering	Subida de archivos maliciosos	10	8	8	9	7	8.4	Crítico
8	T-4	Tampering	Modificación de archivos del sistema	10	4	4	10	4	6.4	Medio

2. Determinar y clasificar las amenazas

Modelado de amenazas



3. Determinar contramedidas y mitigación

Etapas del modelado de amenazas

3. Determinar contramedidas y mitigación

Modelado de amenazas

- Todos los datos obtenidos en la fase anterior son la materia prima para seleccionar las contramedidas adecuadas para acometer las amenazas y evitar que lleguen a materializarse en incidentes de seguridad.
- Una **amenaza puede mitigarse con la implementación de una contramedida.**
- Estas contramedidas se pueden identificar utilizando listas de mapeo de amenazas-contramedidas como STRIDE.

Técnicas de mitigación y amenazas de STRIDE

Paso 3. Determinar contramedidas y mitigación

- Cuando se utiliza **STRIDE**, se puede utilizar la siguiente tabla de mitigación de amenazas para identificar técnicas que se pueden emplear para mitigar las amenazas.

Categoría STRIDE	Tipo de amenaza	Técnicas de mitigación comunes
S – Spoofing	Suplantación de identidad	HTTPS, autenticación, MFA (Autenticación Multifactor), validación de sesiones, SSH con llaves
T – Tampering	Manipulación de datos	Validación de entradas, consultas parametrizadas, hash, controles de integridad
R – Repudiation	Negación de acciones	Logs, auditoría, trazabilidad, registros de actividad
I – Information Disclosure	Divulgación de información	HTTPS, control de acceso, manejo seguro de errores, cabeceras HTTP
D – Denial of Service	Denegación de servicio	Rate limiting, firewalls, límites de recursos, monitoreo
E – Elevation of Privilege	Elevación de privilegios	Principio de mínimo privilegio, validaciones backend, CSP, permisos seguros

Técnicas de mitigación y amenazas de STRIDE

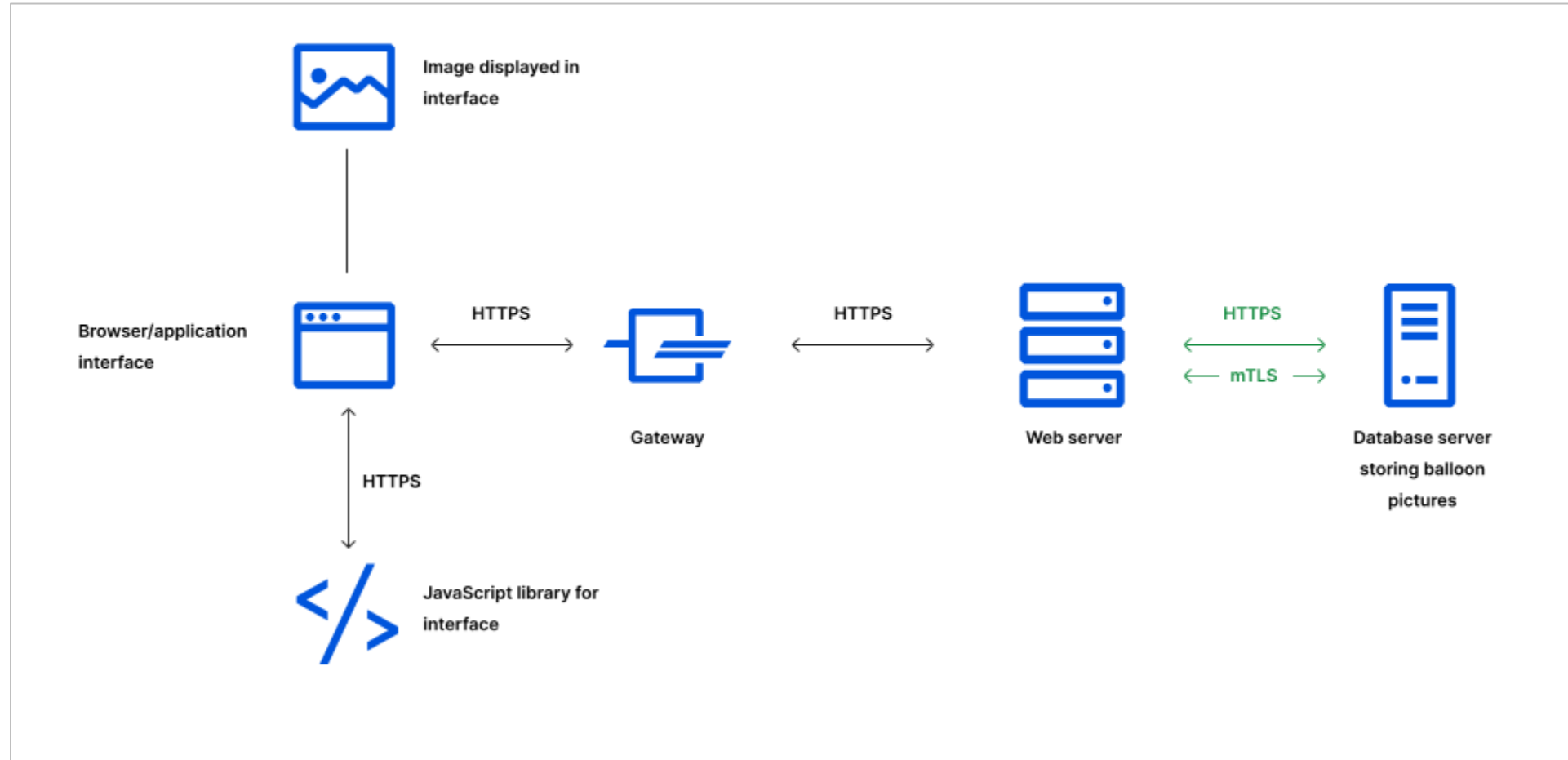
Paso 3. Determinar contramedidas y mitigación

- Ejemplo:

Id	STRIDE	Amenaza	Descripción	Activos afectados	Mitigación	Prioridad
CM-1	S	Suplantación de solicitudes HTTP	Un atacante podría enviar peticiones falsas al backend simulando formularios legítimos.	ACT-1, ACT-12	Validar solicitudes en backend y utilizar tokens CSRF (Cross-Site Request Forgery).	Alta
CM-2	S	Acceso SSH no autorizado	Acceso indebido al servidor Linux mediante credenciales comprometidas.	ACT-14	Deshabilitar acceso root y utilizar autenticación mediante llaves SSH.	Alta
CM-3	S	Suplantación del servidor sin HTTPS	Intercepción del tráfico y falsificación del servidor legítimo.	ACT-10, ACT-17	Implementar HTTPS con certificados TLS y HSTS (HTTP Strict Transport Security).	Crítica

3. Determinar contramedidas y mitigación

Modelado de amenazas



4. Comprobar la mitigación de la amenaza

Etapas del modelado de amenazas

4. Comprobar la mitigación de la amenaza

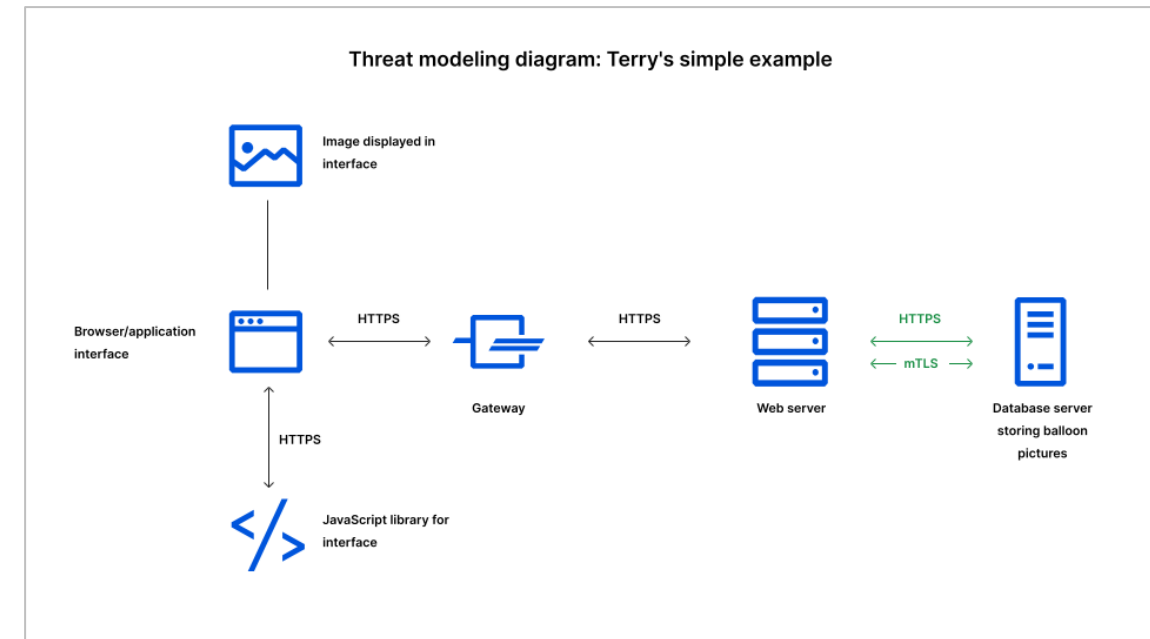
Modelado de amenazas

- Como ya señalamos cuando abordamos los elementos esenciales del modelado de amenazas, es importante incorporar un protocolo para evaluar la **validez** del modelo.
- De nada sirve implementar este proceso si no se incorpora una forma para **comprobar con precisión** que ha identificado con éxito las amenazas y los controles de seguridad pertinentes.
- La evaluación del trabajo nos conduce, directamente, a una de las **claves del modelado de amenazas**: que se **ejecute a lo largo del ciclo de vida del software** o del sistema analizado y no solo en un momento concreto, priorizando, además, las fases tempranas del desarrollo.

4. Comprobar la mitigación de la amenaza

Modelado de amenazas

- A este punto, se podría ejecutar la aplicación en un entorno de prueba y comprobar si:
 1. Los servidores utilizan TLS tal y como está configurado.
 2. Si el servidor web aceptará tráfico HTTP de un servidor no comprobado en lugar del servidor de la base de datos.
- Llevaría a cabo comprobaciones similares para cualquier otra mitigación que haya aplicado.



Herramientas de modelado de amenazas

Modelado de amenazas

Herramientas de modelado de amenazas

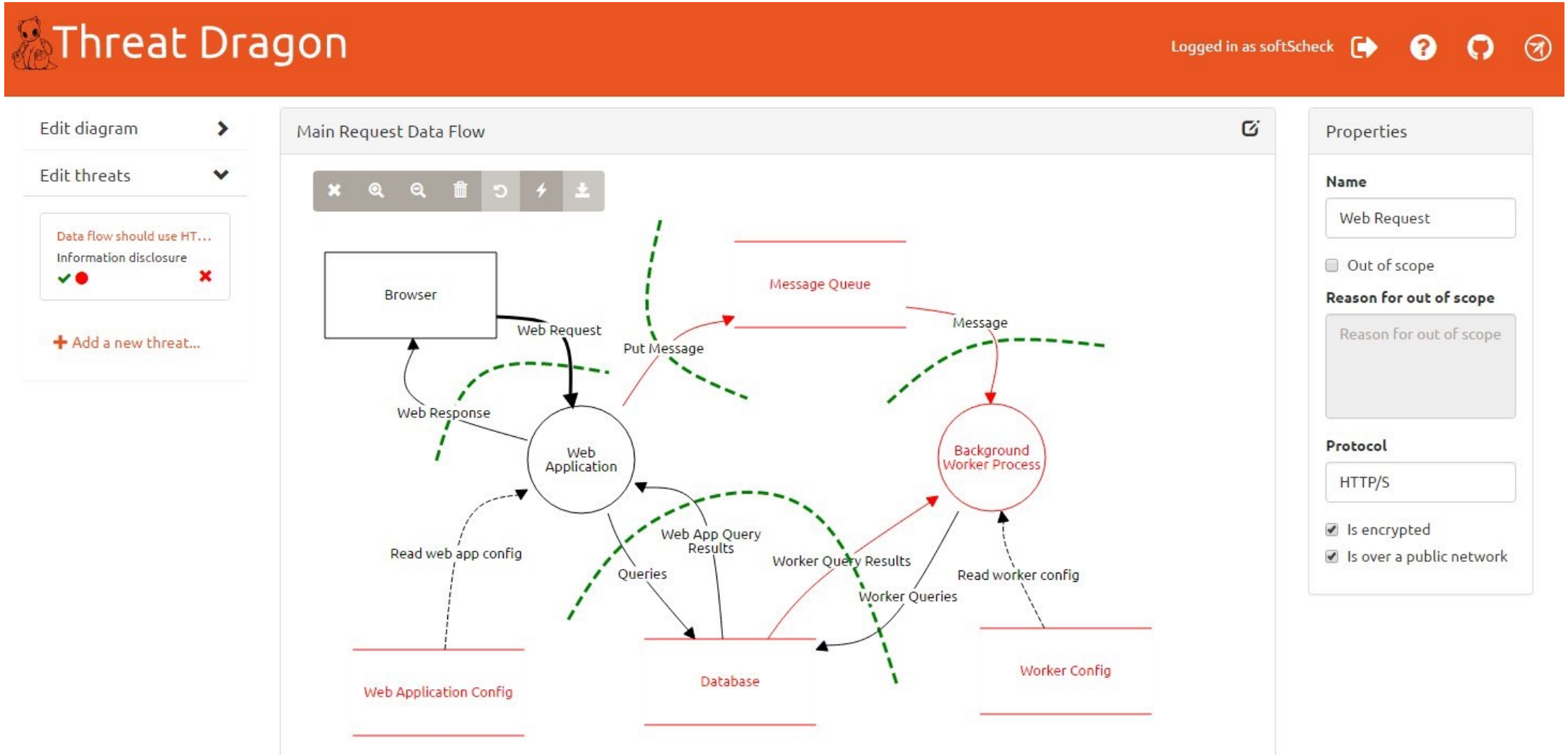
Modelado de amenazas

Más allá de los frameworks, existen en el ámbito de la ciberseguridad algunas herramientas para implementarlos con éxito, pudiendo automatizar tareas y facilitando el modelado de amenazas a lo largo del ciclo de vida del software, dispositivo o sistema. Algunas de estas herramientas para llevar a cabo el modelado de amenazas son:

- **OWASP Threat Dragon.** La Fundación OWASP cuenta con su propia herramienta de código abierto para crear diagramas que permitan visualizar fácilmente los componentes y superficies de ataque. Sirve para registrar amenazas y decidir cómo mitigarlas.
- **Microsoft Threat Modeling Tool.** Herramienta gratuita de modelado de amenazas de Microsoft, se basa en DFD e identifica amenazas según el sistema de clasificación de amenazas STRIDE.
- **IriusRisk.** Una herramienta que dispone de cuestionarios adaptables y que guía a los profesionales a través de aspectos clave como la arquitectura de la aplicación.
- **ThreatModeler.** Esta herramienta sirve para automatizar el modelado de amenazas y está relacionada directamente con VAST.

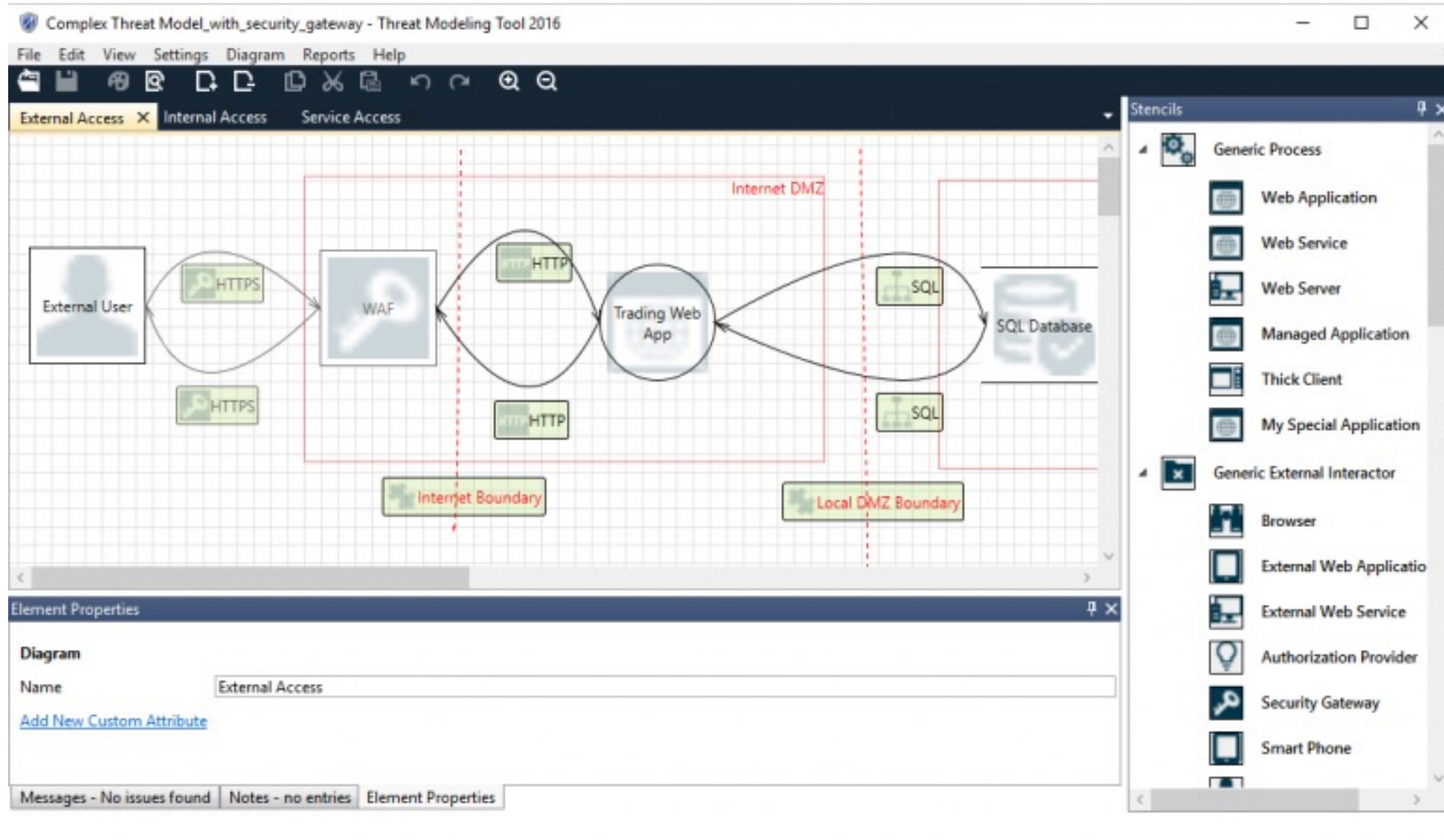
OWASP Threat Dragon

Herramientas de modelado de amenazas



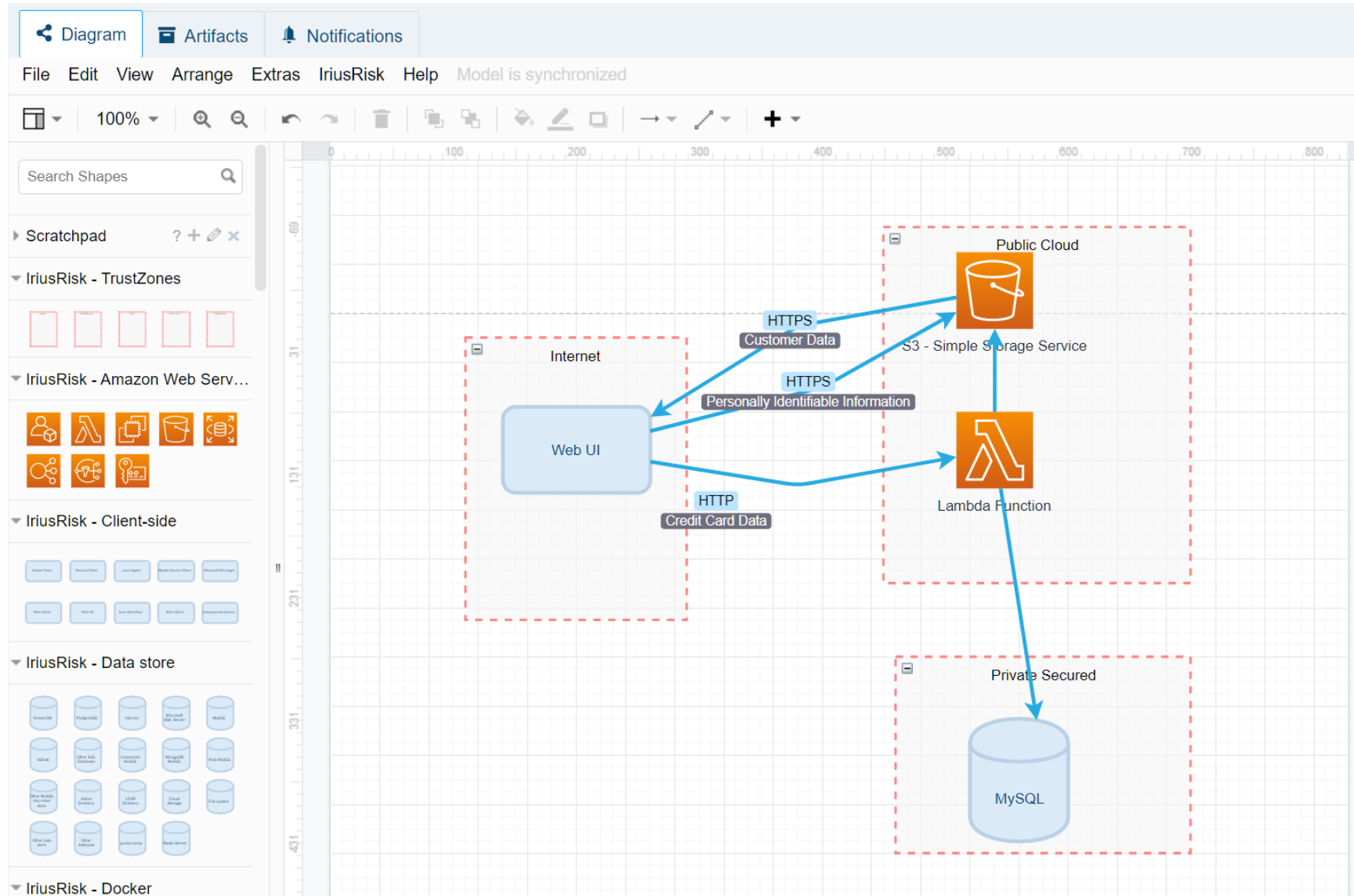
Microsoft Threat Modeling Tool

Herramientas de modelado de amenazas



IriusRisk

Herramientas de modelado de amenazas



ThreatModeler

Herramientas de modelado de amenazas

ThreatModeler™
Security Starts Here

Overview

Diagram

Report

Zoom In
 Zoom Out
 Copy
 Paste
 Undo
 Group
 Ungroup
 Comment
 Security Control
 Import from Template

Overview
 100%
 Select
 Delete
 Redo
 Remove from Group
 Submit for Approval

AWS-1

Toolbox

AWS API Gateway
 AWS CloudFront
 AWS EC2
 AWS EFS

AWS EBS
 AWS Elastic Transcoder
 AWS ElastiCache
 AWS RDS

AWS Route 53
 AWS SES
 AWS IAM
 AWS Lambda

AWS CloudFormation
 AWS ELB
 AWS Docker
 AWS
 AWS
 AWS
 AWS

Diagram

Saved

General

ThreatModeler Software Inc © 2011-2020

[Contact Support](#) |
 [About Us](#) |
 [Academy](#) |
 [License & Agreement](#)

Ejemplo

Modelado de amenazas



Preguntas